

Wie sicher sind unsere Daten in der Esska-App?

Eine Erklärung für Jannis – ohne Technik-Vorwissen nötig

Stand: Juli 2026

Warum dieses Dokument?

Du hast dir Sorgen gemacht, ob unsere Firmendaten – Mitarbeiterdaten, Ausweiskopien, Umsatzzahlen – in dieser App sicher sind. Das ist eine berechnete und wichtige Frage, und du verdienst eine ehrliche, verständliche Antwort. Kein Marketing-Sprech, keine Beschwichtigung – ich erkläre dir, wie das System aufgebaut ist, was die echten Risiken sind, und was wir tun (bzw. noch tun sollten), um sie klein zu halten.

Kurzform vorab: **Die App ist heute schon sicherer aufgebaut als die vorherige Lösung mit WhatsApp, Fotos und Papierzetteln.** Aber es gibt vor dem echten Live-Betrieb noch ein paar Dinge, die wir erledigen sollten – dazu unten mehr.

1. Wo liegen unsere Daten überhaupt?

Stell dir das System wie ein Haus mit drei Räumen vor:



Wichtigster Punkt: Die Daten liegen nicht auf irgendeinem Server in den USA oder China, sondern in einem Hochsicherheits-Rechenzentrum in **Frankfurt** – demselben Rechenzentrums-Standort, den z. B. auch viele deutsche Banken und Versicherungen nutzen.

Vergleich zur alten Lösung: Bei WhatsApp lagen die Ausweisfotos auf den privaten Handys der Mitarbeiter, in der Cloud von WhatsApp/Meta (USA), und potenziell noch auf jedem Handy, das die Nachricht weitergeleitet bekam. Das war deutlich unkontrollierter als jetzt.

2. Wer kann was sehen? (Das Zugriffs-System)

Die App funktioniert wie ein Gebäude mit unterschiedlichen Schlüsseln:

Person	Was sie sehen/tun kann
Du (Admin)	Alles: alle Mitarbeiter, alle Center, alle Umsätze
Mitarbeiter A	Nur die eigenen Stammdaten, nur die eigenen Schichten, nur die Center, denen er zugeordnet ist
Mitarbeiter B	Genau dasselbe – kann Mitarbeiter A's Daten technisch nicht einsehen, auch nicht durch Tricksen mit der Internetadresse

Das Entscheidende: Diese Regel ist **nicht** nur "im Programm eingebaut" (das könnte man umgehen), sondern **direkt in der Datenbank selbst** hart einprogrammiert. Selbst wenn jemand einen Fehler in der sichtbaren App fände, würde die Datenbank die Anfrage trotzdem verweigern – wie ein Tresor mit eigenem Zahlenschloss, unabhängig davon, ob die Zimmertür verschlossen ist. Zwei Sicherheitsebenen statt einer.

3. Die konkreten Gefahren – und wie wahrscheinlich sie sind

● Geringes Risiko (aber real – dagegen sind wir vorbereitet)

„Jemand errät oder stiehlt ein Passwort eines Mitarbeiters“

Das ist das **wahrscheinlichste** Szenario – nicht weil unser System schwach ist, sondern weil Menschen manchmal schwache Passwörter nutzen oder auf Phishing-Mails reinfallen.

Folge, wenn's passiert: Der Angreifer sieht nur die Daten *dieses einen* Mitarbeiters – nicht die ganze Firma. Der Schaden bleibt begrenzt.

Gegenmaßnahme: Mindestlänge für Passwörter ist bereits erzwungen (10 Zeichen). Für deinen Admin-Zugang empfehle ich zusätzlich die „Zwei-Faktor-Anmeldung“ (wie bei Online-Banking: Passwort + Code vom Handy).

„Jemand klickt auf eine gefälschte E-Mail (Phishing)“

Das ist ein Mensch-Problem, keine Technik-Lücke. Jede Firma der Welt ist dem ausgesetzt.

Gegenmaßnahme: Kurze Schulung an alle Mitarbeiter: „Die App fragt niemals per E-Mail nach deinem Passwort.“

● Mittleres Risiko (theoretisch möglich, praktisch sehr unwahrscheinlich)

„Ein Wettbewerber will unsere Umsatzzahlen sehen“

Damit das gelingt, müsste jemand entweder ein gültiges Passwort stehlen, oder eine Sicherheitslücke im Kernsystem selbst finden (Supabase, das von Milliarden-Firmen genutzt und von eigenen Sicherheitsteams rund um die Uhr überwacht wird).

Einschätzung: Sehr unwahrscheinlich. Es gibt für einen Angreifer viel einfachere Wege, an Konkurrenz-Informationen zu kommen (z. B. einfach die Center besuchen und schauen, wie voll sie sind), als in ein gut gesichertes System einzubrechen.

„Die Seite wird 'gescraped' oder automatisch durchsucht“

Automatische Scan-Programme (sog. „Crawler“) durchsuchen ständig das Internet nach offenen Daten.

Bei uns: Es gibt de facto nichts zu finden. Jede Seite außer der Login-Maske verlangt eine Anmeldung. Ein Scanner sieht nur eine leere Anmeldeseite – wie ein verschlossenes Schaufenster.

● Rechtlicher Sonderfall (kein „Hacking“, aber wichtig zu wissen)

„Kann der Staat auf unsere Daten zugreifen?“

Deutsche Behörden: Ja – aber nur mit richterlichem Beschluss, genau wie sie auch deinen Aktenschrank im Büro durchsuchen dürften. Das ist kein App-spezifisches Risiko, das gilt für jede Art der Datenspeicherung, ob Papier oder digital.

US-Behörden: Der Datenbank-Anbieter (Supabase) ist ein US-Unternehmen, auch wenn unsere Daten auf einem Server in Frankfurt liegen. In der Theorie könnten US-Gesetze (der sogenannte „CLOUD Act“) einen Zugriff verlangen. In der Praxis: Das betrifft in der Regel schwere Straftaten (Terrorismus, organisierte Kriminalität) – für einen Modehändler mit Schals ist das ein rein theoretisches Risiko, aber ich nenne es dir der Vollständigkeit halber, weil du danach gefragt hast.

Falls dir das zu unsicher ist: Es gibt die Möglichkeit, komplett auf einen deutschen/europäischen Anbieter umzuziehen (das System ist technisch dafür vorbereitet). Das würde etwas höhere laufende Kosten und etwas mehr Wartungsaufwand bedeuten. Meine Einschätzung: Für unsere Betriebsgröße nicht notwendig, aber deine Entscheidung.

4. Was ist mit den Ausweiskopien? (Besonders sensibel)

Ausweiskopien sind besonders schützenswerte Daten. So sind sie abgesichert:

- Sie liegen in einem **eigenen, verschlossenen Datenbereich** („Bucket“), getrennt von allen anderen Daten
- **Niemand** kann sie über einen normalen Link aufrufen – jedes Mal, wenn ein Foto angezeigt wird, erzeugt das System einen **Einmal-Link**, der nach 60 Sekunden automatisch verfällt
- Nur du als Admin oder der jeweilige Mitarbeiter selbst können auf sein eigenes Dokument zugreifen

Das ist deutlich sicherer als der bisherige Weg, bei dem Ausweisfotos über WhatsApp verschickt wurden und potenziell auf mehreren privaten Handys landeten.

5. Was noch fehlt, bevor wir „scharf“ live gehen

Ehrlich gesagt: Technisch ist die App für unsere Größe gut vorbereitet. Was noch fehlt, ist **Papierkram**, kein Programmieren:

Was	Warum wichtig	Aufwand
Datenschutzerklärung für Mitarbeiter	Gesetzlich vorgeschrieben – Mitarbeiter müssen wissen, welche Daten wir speichern und warum	Entwurf liegt vor, kurze Prüfung reicht meist

Vertrag mit Supabase & Vercel („Auftragsverarbeitungsvertrag“)	Regelt rechtlich, wie diese Anbieter mit unseren Daten umgehen dürfen	10 Minuten Klickarbeit im jeweiligen Dashboard
Löschregeln	Festlegen, wann Daten von ausgeschiedenen Mitarbeitern gelöscht werden	Eine Entscheidung von dir (z. B. „6 Monate nach Saisonende“)
Zwei-Faktor-Anmeldung für deinen Admin-Zugang aktivieren	Schützt dich zusätzlich, falls dein Passwort mal geklaut wird	5 Minuten

Keiner dieser Punkte ist ein „Notfall“ – aber alle sollten erledigt sein, bevor die ersten echten (nicht Test-)Mitarbeiterdaten eingegeben werden.

Zusammenfassung in einem Satz:

Die App speichert unsere Daten in einem deutschen Rechenzentrum, mit strikter Zugriffstrennung zwischen Mitarbeitern und Admin, verschlüsselter Übertragung und einem Sicherheitsniveau, das über dem der bisherigen WhatsApp/Papier-Lösung liegt – die verbleibenden Aufgaben sind rechtliche Formalitäten, keine technischen Schwachstellen.

Wenn du zu einem der Punkte mehr wissen willst oder dir ein bestimmtes Szenario Sorgen macht, das hier nicht behandelt wurde – frag einfach, ich erkläre es gerne genauer.